

系统安全

历年真题考情：本章节以往每次会考2-4分左右，然而在改版之后，考分不太固定，多的时候7分，少的时候1-2分，也有了一些超纲的题型知识点，需要在直播补充，整体属于重要章节。

第二版更新：在第二版教材里对应第4章，改动的不多，经常考的信息安全属性、信息安全技术还是原来那些，此外，就是新增了一些抗攻击技术，以及组织框架，安全架构，风险评估等文科性质内容。

信息安全基础
安全系统组成框架
信息安全技术
信息安全的抗攻击技术
信息安全的保证体系
和评估方法
网络安全技术
网络安全协议

文老师软考教育

信息安全基础知识

文老师软考教育

◆信息安全包括5个基本要素：**机密性、完整性、可用性、可控性与可审查性。**

- (1) 机密性：确保信息**不暴露给未授权的**实体或进程。
- (2) 完整性：只有得到允许的人才能修改数据，并且能够**判别出数据是否已被篡改。**
- (3) 可用性：得到授权的实体**在需要时可访问数据**，即攻击者不能占用所有的资源而阻碍授权者的工作。
- (4) 可控性：可以**控制授权范围内的信息流向及行为方式。**
- (5) 可审查性：对出现的**信息安全问题提供调查的依据和手段。**

◆信息安全的范围包括：**设备安全、数据安全、内容安全和行为安全。**

- (1) 信息系统设备的安全是信息系统安全的**首要问题**，是信息系统安全的物质基础，它包括3个方面：设备的稳定性、可靠性、可用性。
- (2) 数据安全即采取措施确保**数据免受未授权的泄露、篡改和毁坏**，包括3个方面：数据的秘密性、完整性、可用性。
- (3) 内容安全是信息安全在**政治、法律、道德层次上的要求**，包括3个方面：信息内容政治上健康、符合国家法律法规、符合道德规范。
- (4) 信息系统的服务功能是指**最终通过行为提供给用户**，**确保信息系统的行为安全**，才能最终确保系统的信息安全。行为安全的特性包括：行为的秘密性、完整性、可控性。

信息安全基础知识

◆信息的存储安全包括**信息使用的安全、系统安全监控、计算机病毒防治、数据的加密和防止非法的攻击等。**

(1) 信息使用的安全。包括用户的标识与验证、用户存取权限限制。

(2) 系统安全监控。系统必须建立一套安全监控系统，全面监控系统的活动，并随时检查系统的使用情况，一旦有非法入侵者进入系统，能及时发现并采取相应措施，确定和填补安全及保密的漏洞。还应当建立完善的审计系统和日志管理系统，利用日志和审计功能对系统进行安全监控。

(3) 计算机网络服务器必须加装网络病毒自动检测系统，以保护网络系统的安全，防范计算机病毒的侵袭，并且必须定期更新网络病毒检测系统。

◆网络安全

◆**网络安全隐患**体现在：物理安全性、软件安全漏洞、不兼容使用安全漏洞、选择合适的安

◆**网络安全威胁**：非授权的访问、信息泄露或丢失、破坏数据完整性、拒绝服务攻击、利用网络传播病毒。

◆**安全措施的目标**：访问控制、认证、完整性、审计、保密。

信息安全系统的组成框架

◆技术体系：从实现技术上来看，信息安全系统涉及以下技术：

(1) **基础安全设备**包括**密码芯片、加密卡、身份识别卡**等，此外还涵盖运用到**物理安全**的物理环境保障技术，建筑物、机房条件及硬件设备条件满足信息系统的机械防护安全，通过对电力供应设备以及信息系统组件的抗电磁干扰和电磁泄漏性能的选择性措施达到相应的安全目的。

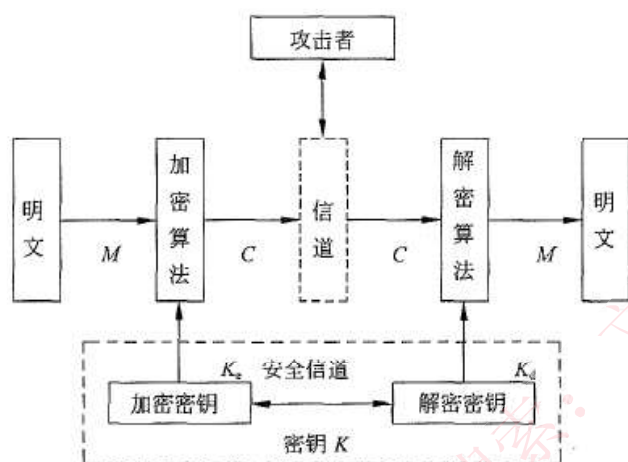
(2) **计算机网络安全**指**信息在网络传输过程中的安全防范**，用于防止和监控未经授权破坏、更改和盗取数据的行为。通常涉及物理隔离，防火墙及访问控制，加密传输、认证、数字签名、摘要，隧道及VPN技术，病毒防范及上网行为管理，安全审计等实现技术。

(3) **操作系统安全**是指操作系统的**无错误配置、无漏洞、无后门、无特洛伊木马等**，能防止非法用户对计算机资源的非法存取，一般用来表达对操作系统的安全需求。操作系统的安全机制包括标识与鉴别机制、访问控制机制、最小特权管理、可信通路机制、运行保障机制、存储保护机制、文件保护机制、安全审计机制，等等。

(4) **数据库安全**可粗略划分为**数据库管理系统安全和数据库应用系统安全**两个部分，主要涉及物理数据库的完整性、逻辑数据库的完整性、元素安全性、可审计性、访问控制、身份认证、可用性、推理控制、多级保护以及消除隐通道等相关技术。

(5) **终端安全设备**从电信网终端设备的角度分为**电话密码机、传真密码机、异步数据密码机**等。

信息安全技术



◆加密技术

一个密码系统，通常简称为密码体制(Cryptosystem)，由五部分组成：

- (1) 明文空间M，它是全体明文的集合。
- (2) 密文空间C，它是全体密文的集合。
- (3) 密钥空间K，它是全体密钥的集合。其中每一个密钥K均由加密密钥 K_e 和解密密钥 K_d 组成，即 $K = \langle K_e, K_d \rangle$ 。
- (4) 加密算法E，它是一组由M至C的加密变换。
- (5) 解密算法D，它是一组由C到M的解密变换。

◆对于明文空间M中的每一个明文M，加密算法E在密钥 K_e 的控制下将明文M加密成密文C： $C = E(M, K_e)$

◆而解密算法D在密钥 K_d 的控制下将密文C解密出同一明文M： $M = D(C, K_d) = D(E(M, K_e), K_d)$

信息安全技术

◆对称加密技术

数据的加密和解密的密钥（密码）是相同的，属于不公开密钥加密算法。其缺点是加密强度不高（因为密钥位数少），且密钥分发困难（因为密钥还需要传输给接收方，也要考虑保密性等问题）。优点是加密速度快，适合加密大数据。

◆常见的对称密钥加密算法如下：

DES：替换+移位、56位密钥、64位数据块、速度快，密钥易产生。

3DES：三重DES，两个56位密钥 K_1 、 K_2 。

加密： K_1 加密→ K_2 解密→ K_1 加密。

解密： K_1 解密→ K_2 加密→ K_1 解密

AES：是美国联邦政府采用的一种区块加密标准，这个标准用来替代原先的DES。对其的要求是“至少像3DES一样安全”。

RC-5：RSA数据安全公司的很多产品都使用了RC-5。

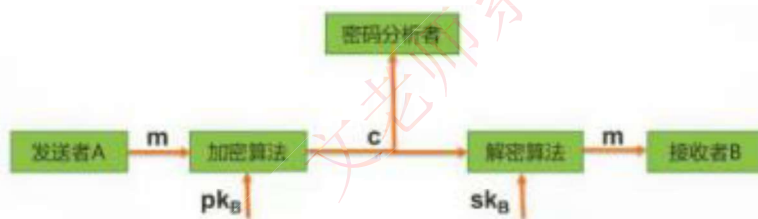
IDEA：128位密钥，64位数据块，比DES的加密性好，对计算机功能要求相对低。

信息安全技术

◆非对称加密技术

数据的**加密和解密的密钥是不同的**，分为公钥和私钥。是**公开密钥加密算法**。其缺点是**加密速度慢**。优点是**安全性高，不容易破解**。

◆非对称技术的原理是：发送者**发送数据时**，使用**接收者的公钥作加密密钥**，**私钥作解密密钥**，这样只有接收者才能解密密文得到明文。安全性更高，因为**无需传输密钥**。但**无法保证完整性**。如下：



◆常见的非对称加密算法如下：

RSA：512位（或1024位）密钥，计算机量极大，难破解。

Elgamal、ECC（椭圆曲线算法）、背包算法、Rabin、D-H等。

信息安全技术

◆相比较可知，对称加密算法密钥一般只有56位，因此**加密过程简单**，**适合加密大数据**，也因此**加密强度不高**；而非对称加密算法密钥有1024位，相应的**解密计算量庞大**，**难以破解**，却**不适合加密大数据**，一般用来加密对称算法的密钥，这样，就**将两个技术组合使用了**，这也是**数字信封的原理**：

◆**数字信封原理**：**信是对称加密的密钥**，数字信封就是**对此密钥进行非对称加密**，具体过程：发送方将数据用对称密钥加密传输，而将对称密钥用接收方公钥加密发送给对方。接收方收到数字信封，用自己的私钥解密信封，取出对称密钥解密得原文。

◆数字信封运用了对称加密技术和非对称加密技术，**本质是使用对称密钥加密数据，非对称密钥加密对称密钥，解决了对称密钥的传输问题**。

◆**对称密钥的分配与管理**：密钥分配一般要解决两个问题：一是**引进自动分配密钥机制**，以提高系统的效率；二是**尽可能减少系统中驻留的密钥量**。

◆控制密钥的安全性主要有两种技术：**密钥标签、控制矢量**。

◆两个用户A和B在**获得共享密钥时可以有4种方式**。

(1) 经过A选取的密钥通过物理手段发送给另一方B。

(2) 由第3方选取密钥，在通过物理手段分别发送给A和B。

(3) A、B事先已有一个密钥，其中一方选取新密钥后，用已有密钥加密该新密钥后发送给另一方。

(4) 三方A、B、C各有一保密信道，C选取密钥后，分别通过A、B各自的保密信道发送。

信息安全技术

◆公钥加密体制的密钥管理：

1. **公开发布**是指用户将自己的公钥发给每一其他用户，或向某一团体广播。
2. **公用目录表**指一个公用的公钥动态目录表，由某个可信的实体或组织（公用目录的管理员）承担该公用目录表的建立、维护以及公钥的分布等。
3. **公钥管理机构**：与公用目录表类似的，不过用公钥管理机构来为各用户建立、维护动态的公钥目录，这种对公钥分配更加严密的控制措施可以增强其安全性。
4. **公钥证书**可以从一定程度上解决以上策略存在的一些不足之处。公钥证书是由证书管理机构CA为用户建立的。

◆**信息摘要**：一段数据的特征信息，当数据发生了改变，信息摘要也会发生改变，发送方会将数据和信息摘要一起传给接收方，接收方会根据接收到的数据重新生成一个信息摘要，若此摘要和接收到的摘要相同，则说明数据正确。信息摘要是由哈希函数生成的。

◆**信息摘要的特点**：不算数据多长，都会产生固定长度的信息摘要；任何不同的输入数据，都会产生不同的信息摘要；单向性，即只能由数据生成信息摘要，不能由信息摘要还原数据。

◆**信息摘要算法**：MD5（产生128位的输出）、SHA-1（安全散列算法，产生160位的输出，安全性更高）。

信息安全技术

◆数字签名：唯一标识一个发送方。

发送者发送数据时，使用发送者的私钥进行加密，接收者收到数据后，只能使用发送者的公钥进行解密，这样就能唯一确定发送方，这也是数字签名的过程。但无法保证机密性。如下：



信息安全技术

◆**公钥基础设施PKI**：是以**不对称密钥加密技术为基础**，以数据机密性、完整性、身份认证和行为不可抵赖性为安全目的，来实施和提供安全服务的具有普适性的**安全基础设施**。

(1) **数字证书**：一个数据结构，是一种由一个**可信任的权威机构签署的信息集合**。在不同的应用中有不同的证书。如X.509证书必须包含下列信息：(1) 版本号(2) 序列号(3) 签名算法标识符(4) 认证机构(5) 有效期限(6) 主题信息(7) 认证机构的数字签名(8) 公钥信息。

公钥证书主要用于确保公钥及其与用户绑定关系的安全。这个公钥就是证书所标识的那个主体的合法的公钥。任何一个用户只要知道签证机构的公钥，就能检查对证书的签名的合法性。如果检查正确，那么用户就可以相信那个证书所携带的公钥是真实的，而且这个公钥就是证书所标识的那个主体的合法的公钥。**例如驾照。**

(2) **签证机构CA**：负责**签发证书、管理和撤销证书**。是所有注册用户所信赖的权威机构，CA在给用户签发证书时要加上自己的数字签名，以保证证书信息的真实性。任何机构可以用CA的公钥来验证该证书的合法性。

考试真题

() 保证信息不泄露给未授权的用户、实体或过程；() 保证信息的完整和准确，防止信息被非法修改。

A.机密性 B.完整性 C.可用性 D.不可否认性

A.机密性 B.完整性 C.可用性 D.不可否认性

答案：A B

以下关于MD5算法的说法中，错误的是()

A.输入任意长度的数据，最终都输出128位

B.该算法结果是不可逆的

C.通过数据碰撞都无法进行解密还原，进行哈希散列时不会出现相同结果

D.输入相同的内容，输出的结果一定是相同的

答案：C

数字签名技术属于信息系统安全管理中保证信息()的技术。

A、保密性 B、可用性 C、完整性 D、可靠性

【答案】C

信息安全技术

◆访问控制是指主体依据某些控制策略或权限对客体本身或是其资源进行的不同授权访问。访问控制包括3个要素，即主体、客体和控制策略。

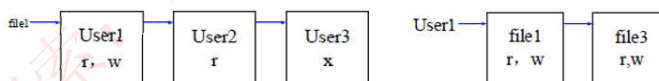
◆访问控制包括认证、控制策略实现和审计3方面的内容。

(1) 访问控制矩阵（ACM）。是通过矩阵形式表示访问控制规则和授权用户权限的方法。主体作为行，客体作为列。

	file1	file2	file3
User1	rw		rw
User2	r	rwX	x
User3	x	r	

(2) 访问控制表（ACL）。目前最流行、使用最多的访问控制实现技术。每个客体有一个访问控制表，是系统中每一个有权访问这个客体的主体的信息。这种实现技术实际上是按列保存访问矩阵。

(3) 能力表。对应于访问控制表，这种实现技术实际上是按行保存访问矩阵。每个主体有一个能力表，是该主体对系统中每一个客体的访问权限信息。使用能力表实现的访问控制系统可以很方便地查询某一个主体的所有访问权限。



(4) 授权关系表。每一行（或者说元组）就是访问矩阵中的一个非空元素，是某一个主体对应于某一个客体的访问权限信息。如果授权关系表按主体排序，查询时就可以得到能力表的效率；如果按客体排序，查询时就可以得到访问控制表的效率。

信息安全的抗攻击技术

◆为对抗攻击者的攻击，密钥生成需要考虑3个方面的因素：增大密钥空间、选择强钥（复杂的）、密钥的随机性（使用随机数）。

◆拒绝服务攻击有许多种，网络的内外用户都可以发动这种攻击。内部用户可以通过长时间占用系统的内存、CPU 处理时间使其他用户不能及时得到这些资源，而引起拒绝服务攻击；外部黑客也可以通过占用网络连接使其他用户得不到网络服务。

◆外部用户针对网络连接发动拒绝服务攻击主要有以下几种模式：消耗资源、破坏或更改配置信息、物理破坏或改变网络部件、利用服务程序中的处理错误使服务失效。

◆分布式拒绝服务DDoS攻击是传统DoS 攻击的发展，攻击者首先侵入并控制一些计算机，然后控制这些计算机同时向一个特定的目标发起拒绝服务攻击。克服了传统DOS受网络资源的限制和隐蔽性两大缺点。

◆拒绝服务攻击的防御方式

(1) 加强对数据包的特征识别，攻击者发送的数据包中是有一些特征字符串。通过搜寻这些特征字符串，就可以确定攻击服务器和攻击者的位置。

(2) 设置防火墙监视本地主机端口的使用情况。如果发现端口处于监听状态，则系统很可能受到攻击。

(3) 对通信数据量进行统计也可获得有关攻击系统的位置和数量信息。在攻击时，攻击数据的来源地址会发出超出正常极限的数据量。

(4) 尽可能的修正已经发现的问题和系统漏洞。

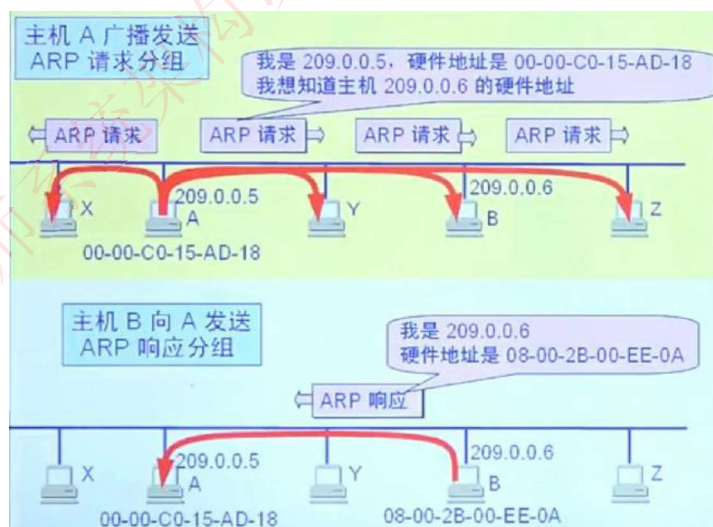
信息安全的抗攻击技术

◆ ARP欺骗

正常ARP原理：如图所示，主机A想知道局域网内主机B的MAC地址，那么主机A就广播发送ARP请求分组，局域网内主机都会收到，但只有B收到解析后知道是请求自己的MAC地址，所以只有B会返回单播的响应分组，告诉A自己的MAC地址。

A收到响应分组后，会建立一个B的IP地址和MAC地址映射，这个映射是动态存在的，如果一定时间AB不再通信，那么就会清空这个地址映射，下次如果还要通信，则重复这个过程。

◆ ARP欺骗原理：上述过程主机A是不管其有没有发送过请求广播分组的，而是只要收到了返回的分组信息，就会刷新IP地址和MAC地址的映射关系，这样就存在安全隐患，假设有主机C，模拟返回分组格式，构造正确的IP地址和自己的MAC地址映射，A收到后也会刷新映射关系，那么当A再次向B发送信息时，实际就发送到了C的MAC地址，数据就被C监听到了。



信息安全的抗攻击技术

◆ ARP欺骗的防范措施：

①在winxp下输入命令：arp-s gate-way-ip gate-way-mac 固化arp 表，阻止arp 欺骗。

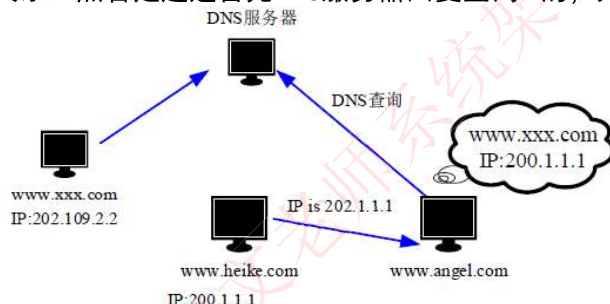
②使用ARP 服务器。通过该服务器查找自己的ARP 转换表来响应其他机器的ARP广播。确保这台ARP 服务器不被黑。

③采用双向绑定的方法解决并且防止ARP 欺骗。

④ARP 防护软件——ARPGuard。通过系统底层核心驱动，无须安装其他任何第三方软件（如WinPcap），以服务及进程并存的形式随系统启动并运行，不占用计算机系统资源。无需对计算机进行IP 地址及MAC 地址绑定，从而避免了大量且无效的工作量。也不用担心计算机在重启后新建ARP 缓存列表，因为此软件是以服务与进程相结合的形式存在于计算机中，当计算机重启后软件的防护功能也会随操作系统自动启动并工作。

信息安全的抗攻击技术

◆ DNS 欺骗首先是冒充域名服务器，然后把查询的IP 地址设为攻击者的IP 地址，这样的话，用户上网就只能看到攻击者的主页，而不是用户想要取得的网站的主页了，这就是DNS 欺骗的基本原理。也即改掉了域名和IP地址的对应关系。黑客是通过冒充DNS服务器回复查询IP的，如下图所示：



◆ DNS欺骗的检测：

①被动监听检测：通过旁路监听的方式，捕获所有DNS 请求和应答数据包，并为其建立一个请求应答映射表。如果在一定的时间间隔内，一个请求对应两个或两个以上结果不同的应答包，则怀疑受到了DNS 欺骗攻击。

②虚假报文探测：采用主动发送探测包的手段来检测网络内是否存在DNS 欺骗攻击者。如果向一个非DNS 服务器发送请求包，正常来说不会收到任何应答，如果收到了应答包，则说明受到了攻击。

③交叉检查查询：在客户端收到DNS 应答包之后，向DNS 服务器反向查询应答包中返回的IP 地址所对应的DNS 名字，如果二者一致说明没有受到攻击，否则说明被欺骗。

信息安全的抗攻击技术

◆ IP欺骗的原理：

IP欺骗的原理：通过编程的方法可以随意改变发出的包的IP 地址，但工作在传输层的TCP 协议是一种相对可靠的协议，不会让黑客轻易得逞。由于TCP 是面向连接的协议，所以在双方正式传输数据之前，需要用“三次握手”来建立一个值得信赖的连接。假设是hosta 和hostb 两台主机进行通信，hostb 首先发送带有SYN 标志的数据段通知hosta 建立TCP 连接，TCP 的可靠性就是由数据包中的多位控制字来提供的，其中最重要的是数据序列SYN 和数据确认标志ACK。B 将TCP 报头中的SYN 设为自己本次连接中的初始值（ISN）。

◆假如想冒充hostb 对hosta 进行攻击，就要先使hostb 失去工作能力。也就是所谓的拒绝服务攻击，让hostb 瘫痪。

◆ IP 欺骗的防范：虽然IP 欺骗攻击有着相当难度，但这种攻击非常广泛，入侵往往从这里开始。预防这种攻击可以删除UNIX 中所有的/etc/hosts.equiv、\$HOME/.rhosts 文件，修改/etc/inetd.conf 文件，使得RPC 机制无法应用。另外，还可以通过设置防火墙过滤来自外部而信源地址却是内部IP的报文。

信息安全的抗攻击技术

◆端口扫描就是尝试与目标主机的某些端口建立连接，如果目标主机该端口有回复（见三次握手中的第二次），则说明该端口开放，即为“活动端口”。

◆扫描原理分类：

（1）全TCP连接。这种扫描方法使用三次握手，与目标计算机建立标准的TCP连接。

（2）半打开式扫描（SYN扫描）。在这种扫描技术中，扫描主机自动向目标计算机的指定端口发送SYN数据段，表示发送建立连接请求。

·如果目标计算机的回应TCP报文中SYN=1 ACK=1，则说明该端口是活动的，接着扫描主机传送一个RST给目标主机拒绝建立TCP连接，从而导致三次握手的过程失败。

·如果目标计算机的回应是RST，则表示该端口为“死端口”，这种情况下，扫描主机不用做任何回应。

（3）FIN扫描。依靠发送FIN来判断目标计算机的指定端口是否是活动的。

发送一个FIN=1的TCP报文到一个关闭的端口时，该报文会被丢掉，并返回一个RST报文。

但是，如果当FIN报文到一个活动的端口时，该报文只是被简单的丢掉，不会返回任何回应。

从FIN扫描可以看出，这种扫描没有涉及任何TCP连接部分。因此，这种扫描比前两种都安全，可以称之为秘密扫描。

（4）第三方扫描。第三方扫描又称“代理扫描”，这种扫描是利用第三方主机来代替入侵者进行扫描。这个第三方主机一般是入侵者通过入侵其他计算机而得到的，该“第三方”主机常被入侵者称之为“肉鸡”。这些“肉鸡”一般为安全防御系数极低的个人计算机。

信息安全的抗攻击技术

◆强化TCP/IP堆栈以抵御拒绝服务攻击

1. 同步包风暴(SYN Flooding)：利用TCP协议缺陷发送大量伪造的TCP连接请求，使得被攻击者资源耗尽。三次握手，进行了两次，不进行第三次握手，连接队列处于等待状态，大量这样的等待，会占满全部队列空间，使得系统挂起。可以通过修改注册表防御SYN Flooding攻击。

2. ICMP攻击。ICMP协议本身的特点决定了它非常容易被用于攻击网络上的路由器和主机。比如，前面提到的“Ping of Death”攻击就是利用操作系统规定的ICMP数据包的最大尺寸不超过64KB这一规定，达到使TCP/IP堆栈崩溃、主机死机的效果。可以通过修改注册表防御ICMP攻击。

3. SNMP攻击。SNMP还能被用于控制这些设备和产品，重定向通信流，改变通信数据包的优先级，甚至断开通信连接。总之，入侵者如果具备相应能力，就能完全接管你的网络。可以通过修改注册表项防御。

系统漏洞扫描指对重要计算机信息系统进行检查，发现其中可能被黑客利用的漏洞。包括基于网络的漏洞扫描（通过网络远程扫描主机）、基于主机的漏洞扫描（在目标系统安装了代理扫描）。

基于网络的漏洞扫描器，一般由以下几个方面组成：漏洞数据库模块、用户配置控制台模块、扫描引擎模块、当前活动的扫描知识库模块、结果存储器和报告生成工具。

基于主机的漏洞扫描优点：扫描的漏洞数量多、集中化管理、网络流量负载小。

信息安全的保证体系和评估方法

◆ GB17859—1999 标准规定了**计算机系统安全保护能力的五个等级**：

◆ **第一级 用户自主保护级**：本级的计算机信息系统可信计算基通过隔离用户与数据，使用户**具备自主安全保护的能力**。本级实施的是自主访问控制，即计算机信息系统可信计算基定义和控制系统中命名用户对命名客体的访问。

◆ **第二级 系统审计保护级**：本级的计算机信息系统可信计算基实施了**粒度更细的自主访问控制**，它通过登录规程、审计安全性相关事件和隔离资源，使用户对自己的行为负责。**在自主访问控制的基础上控制访问权限扩散**。

◆ **第三级 安全标记保护级**：本级的计算机信息系统可信计算基具有系统审计保护级所有功能。此外，还提供有关**安全策略模型、数据标记以及主体对客体强制访问控制的非形式化描述**；具有准确地标记输出信息的能力；消除通过测试发现的任何错误。本级的主要特征是计算机信息系统可信计算基对所有主体及其所控制的客体（例如：进程、文件、段、设备）实施强制访问控制。

◆ **第四级 结构化保护级**：本级的计算机信息系统可信计算基建立于一个明确定义的形式化安全策略模型之上，它要求**将第三级系统中的自主和强制访问控制扩展到所有主体与客体**。此外，还要**考虑隐蔽通道**。对外部主体能够直接或间接访问的所有资源（例如：主体、存储客体和输入输出资源）实施强制访问控制。

◆ **第五级 访问验证保护级**：本级的计算机信息系统可信计算基**满足访问监控器需求**。访问监控器仲裁主体对客体的全部访问。访问监控器本身是抗篡改的；必须足够小，能够分析和测试。与第四级相比，自主访问控制机制**根据用户指定方式或默认方式，阻止非授权用户访问客体**。访问控制的粒度是单个用户。访问控制能够为每个命名客体指定命名用户和用户组，并规定他们对客体的访问模式。没有存取权的用户只允许由授权用户指定对客体的访问权。

信息安全的保证体系和评估方法

◆ 安全风险管理

◆ 在**风险评估实施前，应该考虑**：

- (1) 确定风险评估的范围。
- (2) 确定风险评估的目标。
- (3) 建立适当的组织结构。
- (4) 建立系统性的风险评估方法。
- (5) 获得最高管理者对风险评估策划的批准。

◆ 风险评估的基本要素为**脆弱性、资产、威胁、风险和安全措施**，与这些要素相关的属性分别为业务战略、资产价值、安全需求、安全事件和残余风险，这些也是风险评估要素的一部分。

◆ 风险计算模型包含信息资产、弱点 / 脆弱性、威胁等关键要素。每个要素有各自的属性，信息资产的属性是资产价值，弱点的属性是弱点被威胁利用后对资产带来的影响的严重程度，威胁的属性是威胁发生的可能性。风险计算的过程如下。

- (1) 对信息资产进行识别，并对资产赋值。
- (2) 对威胁进行分析，并对威胁发生的可能性赋值。
- (3) 识别信息资产的脆弱性，并对弱点的严重程度赋值。
- (4) 根据威胁和脆弱性计算安全事件发生的可能性。
- (5) 结合信息资产的重要性和发生安全事件的可能性，计算信息资产的风险值。

考试真题

SYN Flooding攻击的原理是()。

- A. 利用TCP三次握手，恶意造成大量TCP半连接，耗尽服务器资源，导致系统 拒绝服务
- B. 操作系统在实现TCP/IP协议栈时，不能很好地处理TCP报文的序列号紊乱问 题，导致系统崩溃
- C. 操作系统在实现TCP/IP协议栈时，不能很好地处理IP分片包的重叠情况，导 致系统崩溃
- D. 操作系统协议栈在处理IP分片时，对于重组后超大的IP数据包不能很好地处 理，导致缓存溢出而系统崩溃

参考答案(64) A

GB17859—1999 标准规定了计算机系统安全保护能力的五个等级，其中安全等级最高的是（）

- A. 访问验证保护级
- B. 系统设计保护级
- C. 安全标记保护级
- D. 结构化保护级

答案：A

网络安全技术

◆**防火墙是在内部网络和外部因特网之间增加的一道安全防护措施**，分为网络级防火墙和应用级防火墙。

◆**网络级防火墙层次低，但是效率高**，因为其使用包过滤和状态监测手段，一般只检验网络包外在（起始地址、状态）属性是否异常，若异常，则过滤掉，不与内网通信，因此对应用和用户是透明的。

◆**应用级防火墙，层次高，效率低**，因为应用级防火墙会将网络包拆开，具体检查里面的数据是否有问题，会消耗大量时间，造成效率低下，但是安全强度高。

◆**入侵检测系统IDS：监控当前系统/用户行为**，使用入侵检测分析引擎进行分析，这里包含一个知识库系统，囊括了历史行为、特定行为模式等操作，将当前行为和知识库进行匹配，就能检测出当前行为是否是入侵行为，如果是入侵，则记录证据并上报给系统和防火墙，交由它们处理。

◆**入侵防御系统IPS是能够提前发现入侵行为，在其还没有进入安全网络之前就防御。**

◆**杀毒软件**：用于**检测和解决计算机病毒**，与防火墙和IDS要区分，计算机病毒要靠杀毒软件，防火墙是处理网络上的非法攻击。

◆**蜜罐系统**：**伪造一个蜜罐网络引诱黑客攻击**，蜜罐网络被攻击不影响安全网络，并且可以借此了解黑客攻击的手段和原理，从而对安全系统进行升级和优化。

网络安全技术

◆网络攻击和威胁

攻击类型	攻击名称	描述
被动攻击	窃听（网络监听）	用各种可能的合法或非法的手段窃取系统中的信息资源和敏感信息。
	业务流分析	通过对系统进行长期监听，利用统计分析方法对诸如通信频度、通信的信息流向、通信总量的变化等参数进行研究，从而发现有价值的信息和规律。
	非法登录	有些资料将这种方式归为被动攻击方式。

主动攻击	假冒身份	通过欺骗通信系统（或用户）达到非法用户冒充成为合法用户，或者特权小的用户冒充成为特权大的用户的目的。黑客大多是采用假冒进行攻击。
	抵赖	这是一种来自用户的攻击，比如：否认自己曾经发布过的某条消息、伪造一份对方来信等。
	旁路控制	攻击者利用系统的安全缺陷或安全性上的脆弱之处获得非授权的权利或特权。
	重放攻击	所截获的某次合法的通信数据拷贝，出于非法的目的而被重新发送。
	拒绝服务（DOS）	对信息或其它资源的合法访问被无条件地阻止。

网络安全技术

◆渗透测试常用技术手段：

1、**SQL注入**：由于一些程序员在编写Web应用程序时，**没有对用户输入数据的合法性进行严格的判断或过滤**，导致漏洞产生。这些漏洞可能被攻击者恶意利用，通过**在Web应用程序中事先定义好的查询语句的结尾上添加额外的SQL语句**，在管理员不知情的情况下实现非法操作，欺骗数据库服务器执行非授权的任意查询，从而进一步得到相应的数据信息。

◆为了有效**防御SQL注入攻击**，可以采取以下策略：

◆**输入验证与过滤**：对用户输入的数据进行严格的验证和过滤，确保不包含恶意SQL语句。可以使用正则表达式、白名单等方式来限制输入的内容。

◆**使用预编译语句**：预编译语句将SQL语句和数据分开处理，可以有效防止SQL注入攻击。使用预编译语句时，数据库会先对SQL语句进行编译和语法检查，然后再将用户输入的数据作为参数传递给SQL语句执行。

◆**使用ORM框架**：ORM（Object-Relational Mapping）框架可以自动进行参数化查询，降低直接编写SQL语句的风险。ORM框架通过将对象映射到数据库表，实现了对象与数据库之间的交互。

2、**跨站脚本（XSS）攻击**：是一种典型的Web程序漏洞利用攻击。攻击者**利用Web程序对用户输入检查不足的漏洞，将可执行恶意脚本注入网站或Web应用**。当用户访问网页时，这些恶意脚本会被触发执行，从而达到窃取用户个人数据、弹出广告、篡改网页内容等攻击目的。

网络安全技术

为了有效防御XSS攻击，可以采取以下策略：

- ◆ **输入验证与过滤**：对用户输入的数据进行严格的验证和过滤，确保不包含恶意脚本。使用白名单策略，允许的输入格式或字符集应当提前设定。
- ◆ **输出编码**：对输出到网页上的所有数据进行编码，特别是用户输入的数据。常见的编码包括HTML编码、JavaScript编码、URL编码等。这样可以确保用户的输入被当作数据处理，而不是作为代码执行。
- ◆ **设置Cookie属性**：将cookie设置为HTTPOnly，限制JavaScript访问cookie，从而保护用户会话。同时，使用Secure标志，确保cookie只通过HTTPS传输，防止在不安全的连接下被窃取。
- ◆ **使用WAF**：WAF（Web应用防火墙）可以自动识别和阻止XSS攻击，为网站提供额外的安全层。

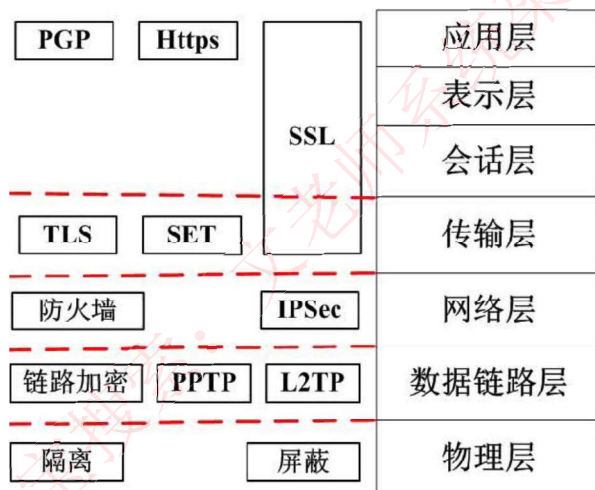
3、**CSRF攻击**是指攻击者通过**伪造用户的请求**，**利用用户在已登录的情况下的身份验证信息**，**向服务器发送恶意请求，从而执行未经用户授权的操作**。

为了有效防御CSRF攻击，以下是一些常见的防御策略：

- ◆ **使用CSRF Token**：在表单提交时，加入一个随机生成的唯一Token，并在服务器端进行验证。只有包含正确Token的请求才被认为是合法的。
- ◆ **检查Referer或Origin头**：通过检查请求头中的Referer或Origin字段，确保请求来源于受信任的页面。但这种方法并不完全可靠，因为Referer头可以被修改。Origin属性只包含了域名信息，不包含具体的URL路径，比Referer更安全可靠。
- ◆ **SameSite Cookie属性**：将Cookie的SameSite属性设置为Strict或Lax，限制跨站点请求携带Cookie。
- ◆ **双重提交Cookie**：在每个请求中，同时通过Cookie和请求参数提交一个相同的Token。服务器端验证两者是否一致。

网络安全协议

◆物理层主要使用物理手段，隔离、屏蔽物理设备等，除会话层外，其它层都是靠协议来保证传输的安全，具体如下图所示：



网络安全协议

◆SSL协议：安全套接字协议，被设计为**加强Web安全传输(HTTP/HTTPS/)**的协议，安全性高，和HTTP结合之后，形成**HTTPS**安全协议，端口号为443。

◆SSH协议：安全外壳协议，被设计为**加强Telnet/FTP安全的传输协议**。

◆SET协议：**安全电子交易协议**主要应用于**B2C模式（电子商务）中保障支付信息的安全性**。SET协议本身比较复杂，设计比较严格，安全性高，它能保证信息传输的机密性、真实性、完整性和不可否认性。SET协议是PKI框架下的一个典型实现，同时也在不断升级和完善，如SET 2.0将支持借记卡电子交易。

◆Kerberos协议：是一种**网络身份认证协议**，该协议的基础是**基于信任第三方**，它提供了在**开放型网络中进行身份认证的方法**，认证实体可以是用户也可以是用户服务。这种认证不依赖宿主机的操作系统或计算机的IP地址，不需要保证网络上所有计算机的物理安全性，并且假定数据包在传输中可被随机窃取和篡改。

考试真题

下面可提供安全电子邮件服务的是（ ）。

A. RSA B. SSL C. SET D. S/MIME

答案：D

解析：MIME(Multipurpose Internet Mail Extensions)中文名为：多用途互联网邮件扩展类型。S/MIME(Secure Multipurpose Internet Mail Extensions)是对MIME在安全方面的扩展。

以下关于第三方认证服务的叙述中，正确的是（ ）。

A. Kerberos认证服务中保存数字证书的服务器叫CA
B. 第三方认证服务的两种体制分别是Kerberos和PKI
C. PKI体制中保存数字证书的服务器叫KDC
D. Kerberos的中文全称是“公钥基础设施”

答案：B

关于SQL注入以下说法错误的是（ ）。

A. 通过编写防注入脚本和查询参数化是避免SQL注入的有效手段
B. 使用ORM可以自动进行参数化查询，但无法减少SQL注入的风险
C. SQL注入是一种典型的攻击手段
D. 使用UNION关键字可以通过SQL拼接，合并结果集拿到敏感信息

答案：B

考试真题

超纲题型猜题技巧

基于任务的访问控制（TBAC）模型由（）组成

- A. 主体、客体、属性、角色、策略
- B. 主体、客体、角色、权限、访问策略
- C. 业务流程、授权主体、受托客体、策略集
- D. 工作流、授权结构体、受托人集、许可集

答案：D

以下灾难中心建设中，灾难恢复级别最高的是（）

- A. 实时数据传输及完整设备支持
- B. 数据0丢失和远程集群支持
- C. 电子传输及完整设备支持
- D. 实时数据传输及远程集群支持

答案：B

谢谢！

文老师软考教育